

EDUCATIONAL, AUTHORISED LAB ASSESSMENT

Footprinting and Reconnaissance

Modules Completed: PM1, PM2, PM4, PM5

A structured reconnaissance lifecycle across public web infrastructure, passive OSINT, enterprise scale attack surface mapping, and local network discovery

Author	Chukwu PraiseGod
Date	17 September 2026
Classification	Educational, Authorised Lab
PM1 Target	networkwalks.com
PM2 Scope	Passive OSINT via Google Hacking Database dorks
PM4 Target	microsoft.com, OSINT only
PM5 Target	192.168.1.0/24, personal local LAN

1. Overview

This project demonstrates a full reconnaissance lifecycle across four distinct environments: public web infrastructure, passive open source intelligence (OSINT), enterprise scale attack surface mapping, and local network discovery.

The objective was not exploitation. It was to understand how much intelligence an attacker can gather about a target before ever attempting to breach it, using only publicly available information and low impact queries. Reconnaissance is often treated as a preliminary checklist item in security training, but as this project shows, it is frequently the single most information rich phase of an attack, since a well executed recon phase can reveal exactly where an attacker would spend their effort without needing to send a single exploit.

2. Executive Summary

Across the four modules, passive techniques alone were enough to expose meaningful, real world risk. The key headline findings were:

- More than 10 unsecured IP cameras found streaming live video feeds publicly, with no authentication required.
- Approximately 9,957 subdomains tied to a single enterprise domain (microsoft.com), discovered entirely through passive sources such as certificate transparency logs.
- A standard WordPress website (networkwalks.com) that revealed its CMS version, plugin versions, hosting stack, and both its defensive controls and its gaps, all from public facing headers and metadata.
- A local network scan that identified an IoT device carrying potential firmware and credential risk.

No exploitation was required at any point to uncover this level of attack surface intelligence.

This project demonstrates that reconnaissance is not only a preliminary step in an assessment, it is often the most information rich phase of an attack, since the majority of what an attacker needs to plan their next move is already public.

3. Methodology

A structured reconnaissance workflow was followed, moving from fully passive techniques toward low impact active queries, so that no stage put unnecessary load or risk on the target systems.

1. **Passive OSINT:** WHOIS registry lookups, Google Hacking Database (GHDB) dorking, certificate transparency log review, and general search engine based reconnaissance. At this stage, no direct queries are sent to the target's live infrastructure.
2. **Low impact active reconnaissance:** direct DNS queries, HTTP header inspection, and technology fingerprinting. These touch the target's infrastructure but do not attempt to alter, disrupt, or exploit anything.

3. **Network discovery:** local subnet scanning and device identification, used to map what is present on a network the tester is authorised to scan.

Tools Used

whois, whatweb, dnsrecon, nslookup, curl, wafw00f, theHarvester, Nmap, Zenmap, and Google Hacking Database (GHDB) dorks.

4. PM1: Target Reconnaissance (networkwalks.com)

This module focused on a single, real website to see how much could be learned about its technology stack, defensive posture, and infrastructure using only standard reconnaissance tooling.

4.1 What Was Discovered

Technology Stack

- WordPress version 7.1, exposed directly through the site's HTML meta generator tag.
- A plugin, WordPress Download Manager version 3.3.58, also version fingerprintable from the page source.
- Apache running on shared hosting infrastructure provided by HostGator.

Exposing exact version numbers like this matters because it lets an attacker skip guesswork: they can go straight to the National Vulnerability Database (NVD) and check whether that specific WordPress or plugin version has a known, unpatched vulnerability, turning a five minute lookup into a shortlist of exploits to try.

Security Controls Present

- HTTPS is enforced across the site, with HTTP requests redirected automatically.
- A ModSecurity Web Application Firewall (WAF) was detected in front of the site, which filters common web attacks such as SQL injection and cross site scripting.
- Session cookies are set with the Secure and HttpOnly flags, reducing the risk of cookie theft over insecure channels or via client side scripts.

Security Gaps Identified

- Several important HTTP security headers are missing, specifically Content Security Policy (CSP), HTTP Strict Transport Security (HSTS), and X Frame Options. Without these, the site has weaker protection against script injection, protocol downgrade attacks, and clickjacking.
- DNSSEC is not enabled on the domain, meaning DNS responses are not cryptographically signed and could, in theory, be spoofed or tampered with in transit.
- The domain's SPF record uses a soft fail policy (~all) instead of a hard fail (-all). In practice, this means that emails spoofed to look like they came from networkwalks.com are more likely to be marked as suspicious rather than outright rejected by receiving mail servers.

Infrastructure Exposure

- The domain's nameservers disclosed their BIND version (9.16.23-RH) in response to a standard query, information which can be used to check for known DNS server vulnerabilities specific to that release.
- The presence of cPanel as the hosting control panel was inferred from SRV records used for autodiscovery of email settings.

4.2 Evidence

Whois Output

WHOIS registration details for networkwalks.com

```

kali@kali: ~/recon
Session Actions Edit View Help

(kali@kali)-[~]
$ mkdir recon

(kali@kali)-[~]
$ cd recon

(kali@kali)-[~/recon]
$ whois networkwalks.com | tee networkwalks-whois.txt
Domain Name: NETWORKWALKS.COM
Registry Domain ID: 2452319255_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.godaddy.com
Registrar URL: http://www.godaddy.com
Updated Date: 2025-11-12T10:08:43Z
Creation Date: 2019-11-06T22:51:46Z
Registry Expiry Date: 2027-11-06T22:51:46Z
Registrar: GoDaddy.com, LLC
Registrar IANA ID: 146
Registrar Abuse Contact Email: abuse@godaddy.com
Registrar Abuse Contact Phone: 480-624-2505
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientRenewProhibited https://icann.org/epp#clientRenewProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: NS6135.HOSTGATOR.COM
Name Server: NS6136.HOSTGATOR.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-09-15T16:47:24Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.

The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain Name: networkwalks.com
Registry Domain ID: 2452319255_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.godaddy.com
Registrar URL: https://www.godaddy.com
Updated Date: 2025-11-12T05:08:41Z
Creation Date: 2019-11-06T17:51:46Z
Registrar Registration Expiration Date: 2027-11-06T17:51:46Z
Registrar: GoDaddy.com, LLC
Registrar IANA ID: 146

```

WhatWeb Output

Technology fingerprint: CMS, plugins, server, and headers

```
kali@kali: ~/recon
Session Actions Edit View Help

(kali@kali)~/recon
$ whatweb networkwalks.com | tee networkwalks-whatweb.txt
http://networkwalks.com [301 Moved Permanently] Apache, Cookies[_wpdm_client], Country[UNITED STATES][US], HTTPServer[Apache], HttpOnly[_wpdm_client], IP[192.232.216.135], RedirectLocation[https://networkwalks.com/], UncommonHeaders[permissions-policy,x-redirect-by,upgrade,referrer-policy,x-endurance-cache-level,x-nginx-cache]
https://networkwalks.com [200 OK] Apache, Bootstrap[7.1], Cookies[_wpdm_client], Country[UNITED STATES][US], Email[info@networkwalks.com], Frame, Google-Tag-Manager, HTML5, HTTPServer[Apache], HttpOnly[_wpdm_client], IP[192.232.216.135], JQuery[3.7.1], MetaGenerator[WordPress 7.1,WordPress Download Manager 3.3.58], Open-Graph-Protocol[website], Script[4684NR-IPIB6amp;pidnVar2=505116amp;pvtVar2=76amp;scvVar2=12,application/json,application/ld+json,module,speculationrules,text/javascript], Title[Networkwalks Academy], UncommonHeaders[permissions-policy,link,upgrade,referrer-policy,x-endurance-cache-level,x-nginx-cache], WordPress[7.1]
https://networkwalks.com/ [200 OK] Apache, Bootstrap[7.1], Country[UNITED STATES][US], Email[info@networkwalks.com], Frame, Google-Tag-Manager, HTML5, HTTPServer[Apache], IP[192.232.216.135], JQuery[3.7.1], MetaGenerator[WordPress 7.1,WordPress Download Manager 3.3.58], Open-Graph-Protocol[website], Script[4684NR-IPIB6amp;pidnVar2=505116amp;pvtVar2=76amp;scvVar2=12,application/json,application/ld+json,module,speculationrules,text/javascript], Title[Networkwalks Academy], UncommonHeaders[permissions-policy,link,upgrade,referrer-policy,x-endurance-cache-level,x-nginx-cache], WordPress[7.1]

(kali@kali)~/recon
$
```

curl Headers

HTTP response headers from curl -I

```
kali@kali: ~/recon
Session Actions Edit View Help

(kali@kali)~/recon
$ whatweb networkwalks.com | tee networkwalks-whatweb.txt
http://networkwalks.com [301 Moved Permanently] Apache, Cookies[_wpdm_client], Country[UNITED STATES][US], HTTPServer[Apache], HttpOnly[_wpdm_client], IP[192.232.216.135], RedirectLocation[https://networkwalks.com/], UncommonHeaders[permissions-policy,x-redirect-by,upgrade,referrer-policy,x-endurance-cache-level,x-nginx-cache]
https://networkwalks.com [200 OK] Apache, Bootstrap[7.1], Cookies[_wpdm_client], Country[UNITED STATES][US], Email[info@networkwalks.com], Frame, Google-Tag-Manager, HTML5, HTTPServer[Apache], HttpOnly[_wpdm_client], IP[192.232.216.135], JQuery[3.7.1], MetaGenerator[WordPress 7.1,WordPress Download Manager 3.3.58], Open-Graph-Protocol[website], Script[4684NR-IPIB6amp;pidnVar2=505116amp;pvtVar2=76amp;scvVar2=12,application/json,application/ld+json,module,speculationrules,text/javascript], Title[Networkwalks Academy], UncommonHeaders[permissions-policy,link,upgrade,referrer-policy,x-endurance-cache-level,x-nginx-cache], WordPress[7.1]
https://networkwalks.com/ [200 OK] Apache, Bootstrap[7.1], Country[UNITED STATES][US], Email[info@networkwalks.com], Frame, Google-Tag-Manager, HTML5, HTTPServer[Apache], IP[192.232.216.135], JQuery[3.7.1], MetaGenerator[WordPress 7.1,WordPress Download Manager 3.3.58], Open-Graph-Protocol[website], Script[4684NR-IPIB6amp;pidnVar2=505116amp;pvtVar2=76amp;scvVar2=12,application/json,application/ld+json,module,speculationrules,text/javascript], Title[Networkwalks Academy], UncommonHeaders[permissions-policy,link,upgrade,referrer-policy,x-endurance-cache-level,x-nginx-cache], WordPress[7.1]

(kali@kali)~/recon
$ nslookup networkwalks.com | tee networkwalks-nslookup
Server: 102.90.139.7
Address: 102.90.139.7#53

Non-authoritative answer:
Name: networkwalks.com
Address: 192.232.216.135
;; communications error to 102.90.139.7#53: timed out

(kali@kali)~/recon
$ curl -I https://networkwalks.com | tee networkwalks-http-response-headers
% Total % Received % Xferd Average Speed Time Time Time Current
0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 0 0
HTTP/2 200
permissions-policy: private-state-token-redemption=(self "https://www.google.com" "https://www.gstatic.com" "https://recaptcha.net" "https://challenges.cloudflare.com" "https://hcaptcha.com"), private-state-token-issuance=(self "https://www.google.com" "https://www.gstatic.com" "https://recaptcha.net" "https://challenges.cloudflare.com" "https://hcaptcha.com")
link: <https://networkwalks.com/wp-json/>; rel="https://api.w.org"/, <https://networkwalks.com/wp-json/wp/v2/pages/53>; rel="alternate"; title="JSON"; type="application/json", <https://networkwalks.com/>; rel=shortlink
set-cookie: _wpdm_client=a905e5dbbc4548abie613f56c664445d; path=/; domain=networkwalks.com; secure; HttpOnly
referrer-policy: no-referrer-when-downgrade
x-endurance-cache-level: 0
x-nginx-cache: WordPress
content-type: text/html; charset=UTF-8
date: Tue, 15 Sep 2026 17:01:17 GMT
server: Apache

(kali@kali)~/recon
```

dnsrecon Results

DNS enumeration output, including SOA, NS, MX, TXT, and SRV records

```

kali@kali: ~/recon
Session Actions Edit View Help
(kali@kali)~/recon
$ dnsrecon -d networkwalks.com | tee networkwalks-dnsrecon
2026-09-15T13:52:57.051034-0400 INFO Starting enumeration for domain: networkwalks.com
2026-09-15T13:52:57.052094-0400 INFO std: Performing General Enumeration against: networkwalks.com ...
2026-09-15T13:52:57.445370-0400 ERROR No answer for DNSSEC query for networkwalks.com
2026-09-15T13:52:57.668487-0400 INFO SOA ns6135.hostgator.com 50.87.144.87
2026-09-15T13:52:58.057148-0400 INFO NS ns6135.hostgator.com 50.87.144.87
2026-09-15T13:52:58.570069-0400 INFO Bind Version for 50.87.144.87 "9.16.23-RH"
2026-09-15T13:52:58.570221-0400 INFO NS ns6136.hostgator.com 192.232.216.131
2026-09-15T13:52:59.089178-0400 INFO Bind Version for 192.232.216.131 "9.16.23-RH"
2026-09-15T13:52:59.564642-0400 INFO MX mail.networkwalks.com 192.232.216.135
2026-09-15T13:52:59.760996-0400 INFO A networkwalks.com 192.232.216.135
2026-09-15T13:53:00.579771-0400 INFO TXT networkwalks.com v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all
2026-09-15T13:53:00.580082-0400 INFO TXT networkwalks.com google-site-verification=rr04eRmqHoWY3XemnizDNVK4q75X-Ij-mjgEeg-UsYI
2026-09-15T13:53:01.367715-0400 INFO Enumerating SRV Records
2026-09-15T13:53:05.024308-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.203.15 443
2026-09-15T13:53:05.024471-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.204.11 443
2026-09-15T13:53:05.024539-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.203.11 443
2026-09-15T13:53:05.024595-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.204.15 443
2026-09-15T13:53:05.024648-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.204.9 443
2026-09-15T13:53:05.024699-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.203.14 443
2026-09-15T13:53:05.024748-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.203.9 443
2026-09-15T13:53:05.024797-0400 INFO SRV _autodiscover._tcp.networkwalks.com cpanel.emaildiscovery.cpanel.net 184.94.204.14 443
2026-09-15T13:53:05.025820-0400 INFO 8 Records Found
2026-09-15T13:53:05.026076-0400 INFO Completed enumeration for domain: networkwalks.com
(kali@kali)~/recon
$

```

nslookup Output

A record resolution via public DNS resolver

```

kali@kali: ~/recon
Session Actions Edit View Help
(kali@kali)~/recon
$ nslookup networkwalks.com | tee networkwalks-nslookup
Server:      8.8.8.8
Address:     8.8.8.8#53

Non-authoritative answer:
Name:   networkwalks.com
Address: 192.232.216.135
(kali@kali)~/recon
$

```

wafw00f Output

WAF detection result confirming ModSecurity

```

(kali@kali)~/recon
$ wafw00f networkwalks.com | tee networkwalks-waf-recon

  W00f!

  404 Hack Not Found
  405 Not Allowed
  403 Forbidden
  502 Bad Gateway
  500 Internal Error

~ WAFW00F : v2.4.2 ~
The Web Application Firewall Fingerprinting Toolkit

[*] Checking https://networkwalks.com
[+] The site https://networkwalks.com is behind ModSecurity (SpiderLabs) WAF.
[-] Number of requests: 2
(kali@kali)~/recon
$

```

5. PM2: Passive OSINT (Google Dorking)

This module used the Google Hacking Database (GHDB), a curated collection of search engine queries known as dorks, to find sensitive or exposed content that search engines have already indexed. Because it relies entirely on existing search results, this technique never sends a single request to the exposed device or file itself until the tester chooses to verify a result.

5.1 High Impact Finding

Over 10 publicly accessible IP cameras identified

Found using dorks such as `intitle:"webcamXP" inurl:8080`. None of the cameras required authentication, and their live feeds were accessible over plain HTTP.

Key characteristics of this finding:

- No authentication was required to view any of the ten identified camera feeds.
- All feeds were accessible over unencrypted HTTP on non standard ports, a common signature of consumer grade camera software such as webcamXP and Webcam 7.
- It is likely that the majority of these camera owners are unaware their devices are exposed to the public internet, since this kind of exposure usually results from a default configuration being left unchanged during installation.

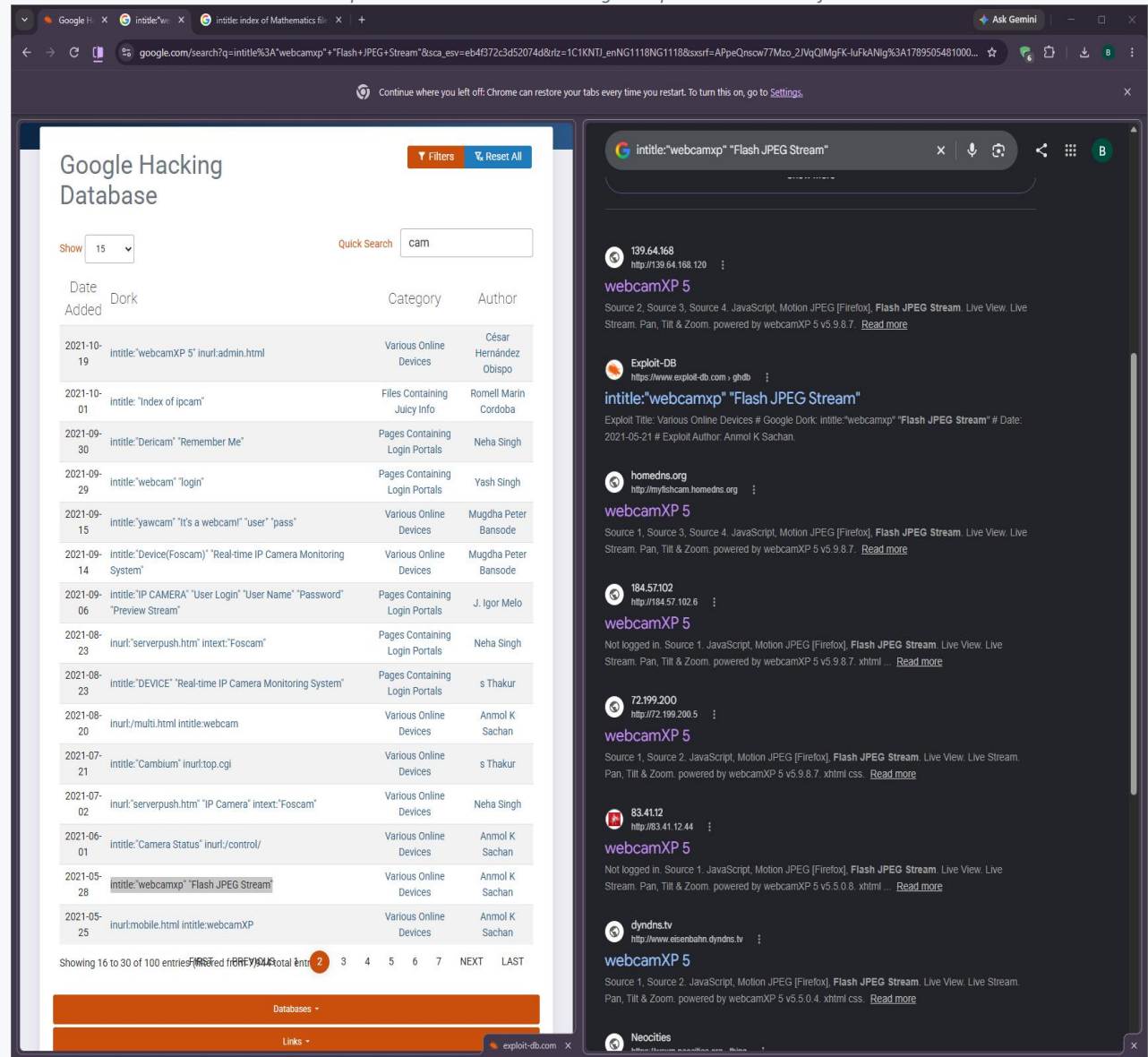
5.2 Why This Matters

An exposed, unauthenticated camera feed is not just a technical curiosity. It provides genuine capability to an attacker or opportunistic observer, including:

- Physical surveillance of a home, office, or facility without the owner's knowledge.
- Behavioural tracking, such as learning when a location is occupied or unoccupied.
- Facility reconnaissance ahead of a physical intrusion, including learning entry points, security camera placement, and staff routines.

5.3 Evidence

Example GHDB search result showing an exposed camera interface



The screenshot displays a Google Hacking Database (GHDB) search result for the query `intitle:webcamxp "Flash JPEG Stream"`. The search results are shown in a table with columns for Date Added, Dork, Category, and Author. The results list various online devices and login portals that contain the specified dork. The search results are sorted by date added, showing results from 2021-05-25 to 2021-10-19. The search results are displayed in a table with columns for Date Added, Dork, Category, and Author. The search results are sorted by date added, showing results from 2021-05-25 to 2021-10-19.

Date Added	Dork	Category	Author
2021-10-19	<code>intitle:"webcamXP 5" inurl:admin.html</code>	Various Online Devices	César Hernández Obispo
2021-10-01	<code>intitle:"Index of ipcam"</code>	Files Containing Juicy Info	Romell Marin Cordoba
2021-09-30	<code>intitle:"Dericam" "Remember Me"</code>	Pages Containing Login Portals	Neha Singh
2021-09-29	<code>intitle:"webcam" "login"</code>	Pages Containing Login Portals	Yash Singh
2021-09-15	<code>intitle:"jawcam" "It's a webcam!" "user" "pass"</code>	Various Online Devices	Mugdha Peter Bansode
2021-09-14	<code>intitle:"Device(Foscam)" "Real-time IP Camera Monitoring System"</code>	Various Online Devices	Mugdha Peter Bansode
2021-09-06	<code>intitle:"IP CAMERA" "User Login" "User Name" "Password" "Preview Stream"</code>	Pages Containing Login Portals	J. Igor Melo
2021-08-23	<code>inurl:"serverpush.htm" intext:"Foscam"</code>	Pages Containing Login Portals	Neha Singh
2021-08-23	<code>intitle:"DEVICE" "Real-time IP Camera Monitoring System"</code>	Pages Containing Login Portals	s Thakur
2021-08-20	<code>inurl:/multi.html intitle:webcam</code>	Various Online Devices	Anmol K Sachan
2021-07-21	<code>intitle:"Cambium" inurl:top.cgi</code>	Various Online Devices	s Thakur
2021-07-02	<code>inurl:"serverpush.htm" "IP Camera" intext:"Foscam"</code>	Various Online Devices	Neha Singh
2021-06-01	<code>intitle:"Camera Status" inurl:/control/</code>	Various Online Devices	Anmol K Sachan
2021-05-28	<code>intitle:"webcamxp" "Flash JPEG Stream"</code>	Various Online Devices	Anmol K Sachan
2021-05-25	<code>inurl:mobile.html intitle:webcamXP</code>	Various Online Devices	Anmol K Sachan

Showing 16 to 30 of 100 entries. [Previous](#) [Next](#) [Last](#)

Search results for `intitle:webcamxp "Flash JPEG Stream"` are displayed on the right side of the page. The results show various online devices and login portals that contain the specified dork. The search results are sorted by date added, showing results from 2021-05-25 to 2021-10-19.

6. PM4: Enterprise OSINT (microsoft.com)

This module used theHarvester, an OSINT tool that queries a range of public sources including certificate transparency (CT) logs, search engines, and DNS aggregators, to map the externally visible footprint of a large enterprise domain. Certificate transparency logs exist so that anyone can audit which TLS certificates have been issued for a domain, but as a side effect, they also publicly record every subdomain a certificate was ever issued for, which makes them an extremely rich, entirely passive source of subdomain intelligence.

6.1 Results Summary

Category	Count	Notes
Subdomains discovered	~9,957	Primarily sourced from certificate transparency logs and public DNS aggregators
Email addresses identified	3	Automated and security contact addresses, not personal accounts
IP addresses	46	Spread across Microsoft's global cloud and content delivery infrastructure
ASNs	6	Autonomous System Numbers identifying the network blocks in use

6.2 Observations

- Numerous pre production and internal facing environments were visible, identifiable by naming patterns such as -dev, -test, -ppe (pre production environment), and -staging.
- Subdomains with internal sounding names, such as those under a corp namespace, were also visible, having leaked into public certificate transparency logs even though they appear to be intended for internal use only.

This demonstrates a subtle but important point: certificate transparency, a system designed purely for security and accountability, also leaks internal naming conventions and infrastructure structure as an unavoidable side effect.

6.3 Key Lesson

The attack surface of large organisations is partially visible by design, even without any direct interaction with their systems. Anyone can read what has already been made public through the certificate ecosystem alone.

6.4 Evidence

theHarvester output with Baidu as the data source

theHarvester run using Baidu as the sole source, limit 1000

```
kali@kali: ~/recon
Session Actions Edit View Help
(kali@kali)-[~]
$ cd recon
(kali@kali)-[~/recon]
$ theHarvester -d microsoft.com -l 1000 -b baidu | tee theharvester-microsoft.txt
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*                                     *
* [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] *
* [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] *
* [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] [I] *
*                                     *
* theHarvester 4.10.1                 *
* Coded by Christian Martorella        *
* Edge-Security Research               *
* cmartorella@edge-security.com        *
*                                     *
*****

[*] Target: microsoft.com
[*] Searching Baidu.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.

(kali@kali)-[~/recon]
```

theHarvester output with all sources

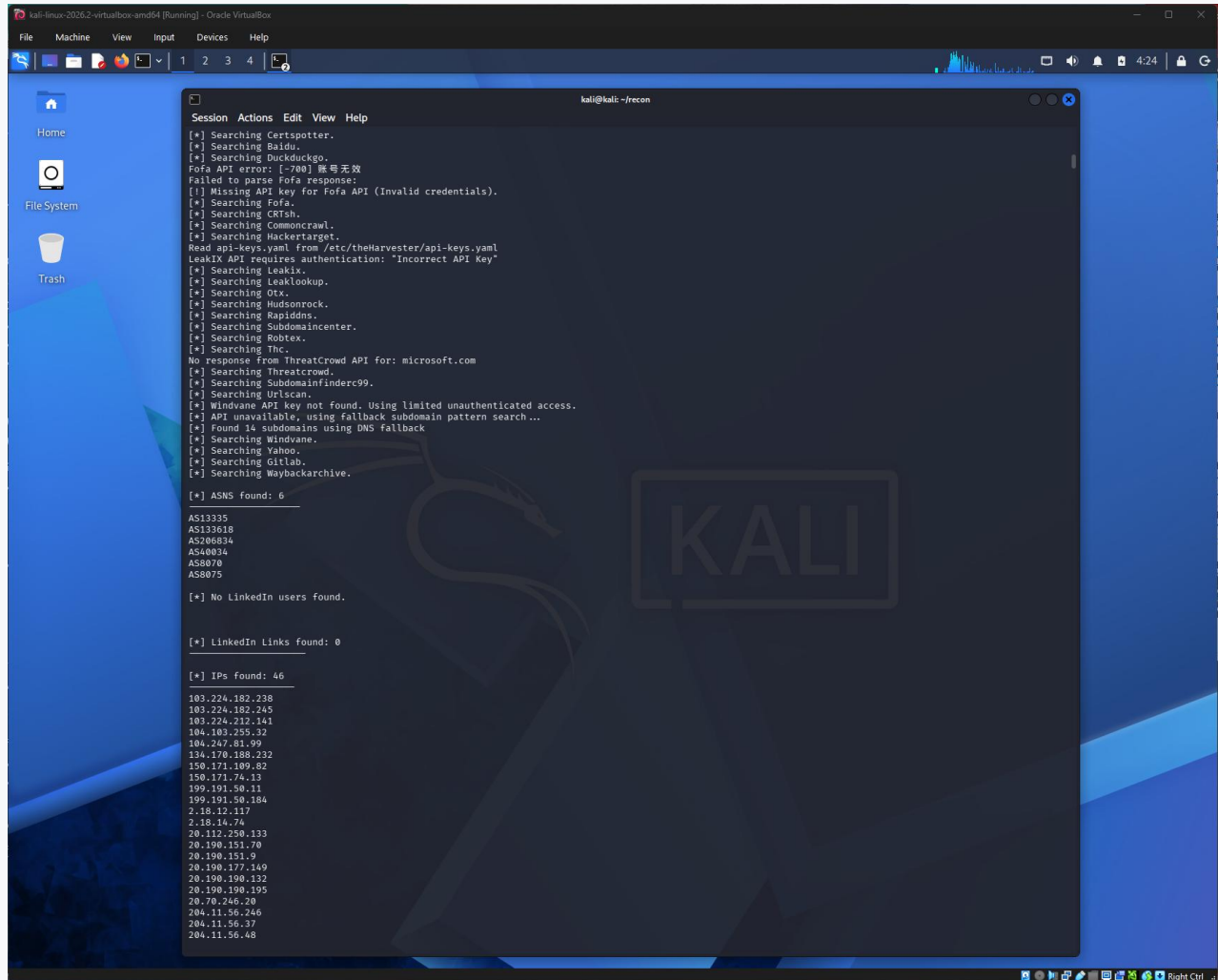
theHarvester run using all available sources, limit 50, page 1 of results

```

kali@kali: ~/recon
kali@kali:~/recon$ theHarvester -d microsoft.com -l 50 -b all | tee theharvester-all-microsoft.txt
2026-09-17 04:19:20,092 - theHarvester.discovery.hudsonrocksearch - INFO - Starting Hudson Rock processing for: microsoft.com
2026-09-17 04:19:20,094 - theHarvester.discovery.hudsonrocksearch - INFO - Starting Hudson Rock search for: microsoft.com
2026-09-17 04:19:44,108 - theHarvester.discovery.hudsonrocksearch - INFO - Domain statistics: 602369 total compromised, 16140 employees, 581626 users
2026-09-17 04:19:44,110 - theHarvester.discovery.hudsonrocksearch - INFO - Extracted 43 hosts from employee URLs
2026-09-17 04:19:45,112 - theHarvester.discovery.hudsonrocksearch - INFO - Hudson Rock search completed. Found 43 hosts, 0 IPs, 0 emails
2026-09-17 04:19:45,112 - theHarvester.discovery.hudsonrocksearch - INFO - Hudson Rock processing completed successfully: 43 hosts, 0 IPs, 0 emails, 0 steal
ers
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* theHarvester
*
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: microsoft.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bevigil search for word: 'microsoft.com'
Error Message:
[!] Missing API key for bevigil.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for Bitbucket.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process BullWith search for word: 'microsoft.com'
Error Message:
[!] Missing API key for bufferoverun.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to perform BullWith search for word: 'microsoft.com'
A Missing Key Error occurred in bullwith:
[!] Missing API key for BullWith.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process brave search for word: 'microsoft.com'
Error Message:
[!] Missing API key for Brave Search.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Censys API key is missing or invalid:
[!] Missing API key for Censys ID and/or Secret.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing key error occurred in criminalip:
[!] Missing API key for criminalip.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing key error occurred in dehashed:
[!] Missing API key for Dehashed.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for DNSDumpster.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
A Missing key error occurred in fullhunt:
[!] Missing API key for fullhunt.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Error initializing SearchGithubCode:
[!] Missing API key for Github.
A Missing key error occurred in github-code:
[!] Missing API key for Github.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

```



```

kali@kali: ~/recon
[*] Searching Certspotter.
[*] Searching Baidu.
[*] Searching Duckduckgo.
Fofa API error: [-700] 账号无效
Failed to parse fofa response:
[!] Missing API key for Fofa API (Invalid credentials).
[*] Searching Fofa.
[*] Searching CRTsh.
[*] Searching Commoncrawl.
[*] Searching Hackertarget.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
LeakIX API requires authentication: "Incorrect API Key"
[*] Searching Leakix.
[*] Searching Leaklookup.
[*] Searching Otx.
[*] Searching Hudsonrock.
[*] Searching Rapidns.
[*] Searching Subdomaincenter.
[*] Searching Robtex.
[*] Searching Thec.
No response from ThreatCrowd API for: microsoft.com
[*] Searching Threatcrowd.
[*] Searching Subdomainfinder99.
[*] Searching Urlscan.
[*] Windvane API key not found. Using limited unauthenticated access.
[*] API unavailable, using fallback subdomain pattern search...
[*] Found 14 subdomains using DNS fallback
[*] Searching Windvane.
[*] Searching Yahoo.
[*] Searching Gitlab.
[*] Searching Waybackarchive.

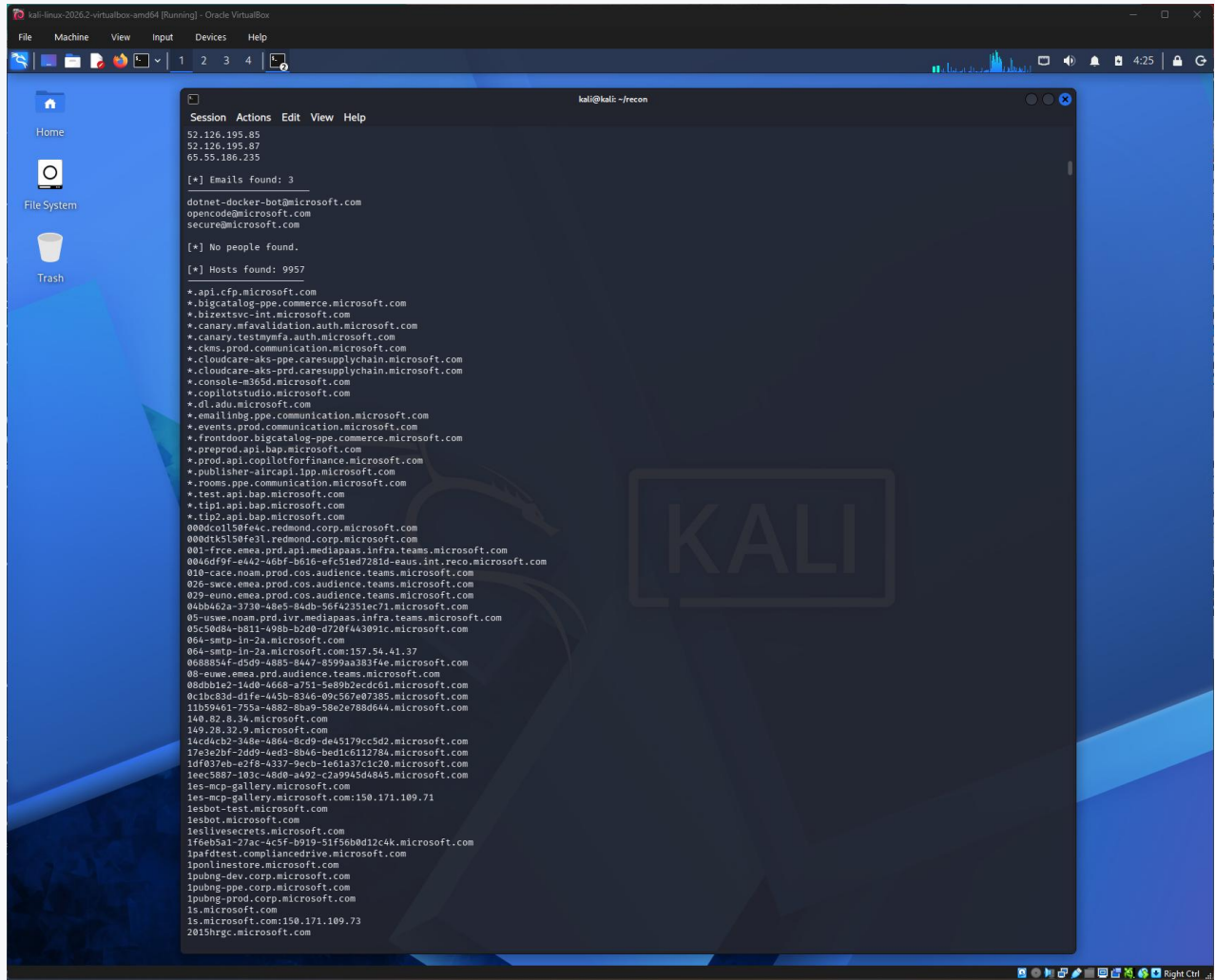
[*] ASNs found: 6
AS13335
AS133618
AS206034
AS40034
AS8070
AS8075

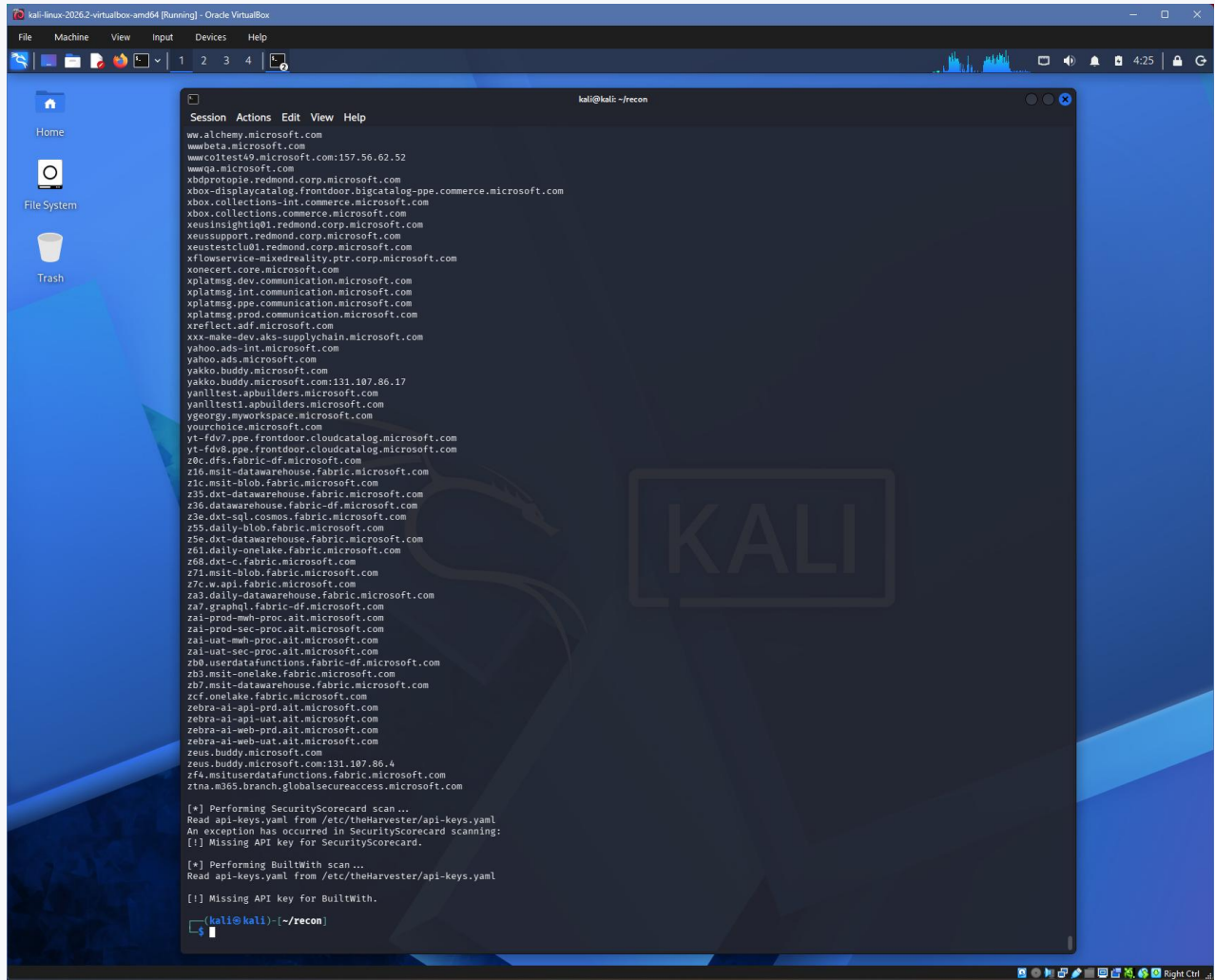
[*] No LinkedIn users found.

[*] LinkedIn Links found: 0

[*] IPs found: 46
103.224.182.238
103.224.182.245
103.224.212.141
104.103.295.32
104.267.61.99
134.170.188.232
150.171.109.82
150.171.74.13
199.191.50.11
199.191.50.184
2.18.12.117
2.18.14.74
20.112.250.133
20.190.151.70
20.190.151.9
20.190.177.140
20.190.190.132
20.190.190.195
20.70.246.20
204.11.56.246
204.11.56.37
204.11.56.48

```





7. PM5: Local Network Discovery Using Zenmap (192.168.1.0/24)

This module shifted from internet facing reconnaissance to the tester's own local network, using Zenmap, the graphical front end for Nmap, to identify every live device on the subnet and gather basic identifying information about each one.

7.1 Scan Results

- A total of 4 live hosts were discovered on the /24 subnet.
- One notable device was identified as an IoT system, based on its MAC address vendor lookup pointing to a Qingdao based electronics manufacturer.

7.2 Risk Insight

IoT devices are worth flagging specifically because, as a class of device, they carry a consistently higher risk profile than typical laptops or phones. Common issues include:

- Running outdated firmware that is rarely, if ever, updated by the end user.
- Shipping with weak or default credentials that are often never changed after setup.
- Lacking network segmentation, meaning they sit on the same network as sensitive devices rather than being isolated.

7.3 Security Concern

Pivot point risk

If the identified IoT device were compromised, an attacker with a foothold on it could use it as a pivot point to reach other devices on the same network segment, including personal computers and other trusted systems. This is why network segmentation, keeping IoT devices on their own isolated VLAN, is considered a baseline control rather than an optional extra.

7.4 Evidence

Zenmap ping scan result output

Zenmap host discovery scan showing live hosts, IPs, and MAC addresses

Target: 192.168.1.0/24 Profile: Ping scan Scan Cancel

Command: `nmap -sn 192.168.1.0/24`

Hosts Services

OS Host

Nmap Output Ports / Hosts Topology Host Details Scans

192.168.1.1 Starting Nmap 7.95 (<https://nmap.org>) at 2026-09-17 16:07 W. Central Africa Standard Time
Nmap scan report for 192.168.1.1
Host is up (0.0020s latency).
MAC Address: 18:B0:A4:E0:A4:D8 (Unknown)

192.168.1.3 Nmap scan report for 192.168.1.3
Host is up (0.047s latency).
MAC Address: 38:64:07:FA:02:FC (Qingdao Intelligent&Precise Electronics)

192.168.1.8 Nmap scan report for 192.168.1.8
Host is up (0.076s latency).
MAC Address: 1A:3C:DD:31:1D:E4 (Unknown)

192.168.1.9 Nmap scan report for 192.168.1.9
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.47 seconds

Network Topology

Exported network topology diagram for the 192.168.1.0/24 subnet

Target: 192.168.1.0/24 Profile: Ping scan Scan Cancel

Command: `nmap -sn 192.168.1.0/24`

Hosts Services

OS Host

Nmap Output Ports / Hosts Topology Host Details Scans

Hosts Viewer Fisheye Controls

Legend Save Graphic

192.168.1.9

192.168.1.1

localhost

192.168.1.3

192.168.1.8

Filter Hosts

8. Risk Summary

Severity	Count	Key Issues
High	1	Exposed, unauthenticated IP cameras
Medium	4	CMS and plugin version disclosure, missing HTTP security headers
Low	3	SPF misconfiguration, DNSSEC absence, IoT device risk on the LAN
Info	5	OSINT exposure and general infrastructure insights

9. Recommendations

9.1 Web Security (PM1)

- Remove the WordPress version string from the site's meta generator tag, and keep both WordPress core and all installed plugins updated to their latest stable releases.
- Implement the missing HTTP security headers: Content Security Policy, HTTP Strict Transport Security, and X Frame Options, to close the gaps identified in this assessment.
- Suppress the BIND version string on the domain's nameservers so it is no longer disclosed in response to standard DNS queries.
- Enable DNSSEC on the domain to provide cryptographic assurance against DNS spoofing and cache poisoning.
- Harden the domain's SPF record by switching from a soft fail (~all) to a hard fail (-all) policy, and deploy a DMARC policy alongside it to further reduce the risk of email spoofing.

9.2 OSINT Exposure (PM2)

- Secure any internet facing devices, particularly IP cameras, by enforcing authentication on every management interface.
- Disable public exposure of devices that do not need to be reachable from the open internet.
- Where remote access is genuinely required, use a VPN based access model rather than exposing the device directly.

9.3 Network Security (PM5)

- Isolate IoT devices on their own VLAN, separate from workstations and other trusted systems, so a compromise cannot spread laterally.
- Perform a follow up service enumeration scan (nmap -sV -sC) against the identified IoT device to confirm open ports and running services.
- Apply firmware updates to IoT devices regularly, and check the manufacturer's support pages periodically for new releases.

10. Conclusion

From a single small business domain to a global enterprise footprint, this assessment demonstrates how open source intelligence and low noise, low impact techniques can reveal a great deal about a target before any exploitation is attempted, including:

- Technology stacks, down to specific CMS and plugin version numbers.
- Misconfigurations in email authentication and HTTP security headers.
- Hidden or internal facing infrastructure, exposed indirectly through certificate transparency logs.
- Real world security risks, such as unauthenticated cameras and vulnerable IoT devices, that exist entirely independently of the primary target being assessed.

Taken together, these four modules reinforce a central idea in offensive security: the reconnaissance phase deserves the same rigor and attention as exploitation, because in many real engagements, it is where the majority of usable intelligence is actually found.

11. Portfolio Note

This report is part of my ongoing, hands on Cybersecurity Internship at NetworkWalks. Additional labs and case studies are available on my GitHub profile.

This report documents my coursework and lab based practice completed for educational purposes. All targets were either explicitly authorised lab systems, the author's own network, or public information gathered through passive OSINT with no direct system access. Distribution should be limited to course instructors, assessors, and the author's professional portfolio audience.